Phishing Email Detection & Awareness Report - TASK2

1. Introduction

This report presents the results of a phishing email analysis conducted on four provided email samples targeting personal and corporate users.

The purpose of this assessment is to identify phishing indicators, explain the attack methods in a controlled environment, and provide actionable recommendations to improve organizational security awareness.

2. Objectives

- Identify common phishing indicators and social engineering tactics
- Perform basic security testing on email headers and embedded links
- Classify emails based on risk severity (Phishing/Suspicious/Safe)
- Provide prevention strategies in simple, business-friendly language

3. Tools Used

- Web Browser: Manual inspection of destination URLs and payloads
- Google Admin Toolbox Messageheader: Header analysis and sender verification
- Text Editor: Inspection of raw .eml files and HTML code

4. Methodology

1. Four .eml files were collected as samples representing financial phishing attacks.
2. Raw email headers were extracted and analyzed using Google Messageheader.
3. Embedded HTML links and Call-to-Action (CTA) buttons were manually inspected using browser tools.
4. Display names, originating domains, and psychological triggers were documented.
5. Findings were analyzed and categorized to generate security awareness guidelines.

5. Threat Findings

5.1 Axis Bank Impersonation (Financial Phishing)

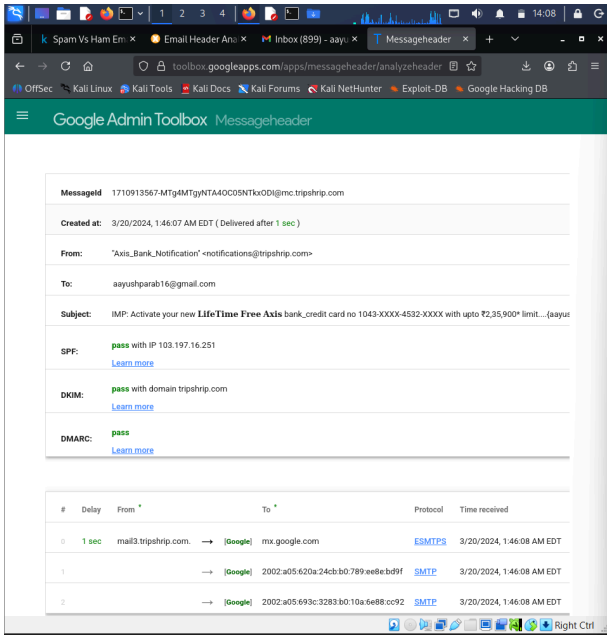
- Risk Level: High

Description: The email mimics an official Axis Bank notification offering a pre-approved credit card. The attacker utilized display name spoofing to hide the actual sending domain (tripshrip.com).

Impact:

- Theft of sensitive financial credentials
- Unauthorized access to bank accounts
- Redirection to malicious or phishing websites

Proof of Concept: Payload used: Malicious CTA link redirecting to mc.tripshrip.com



Recommendation:

- Verify the true sender by expanding the display name
- Hover over CTA buttons to inspect the destination URL before clicking
- Navigate to the official bank website manually instead of using email links

5.2 Credit Score & Personal Loan Trap

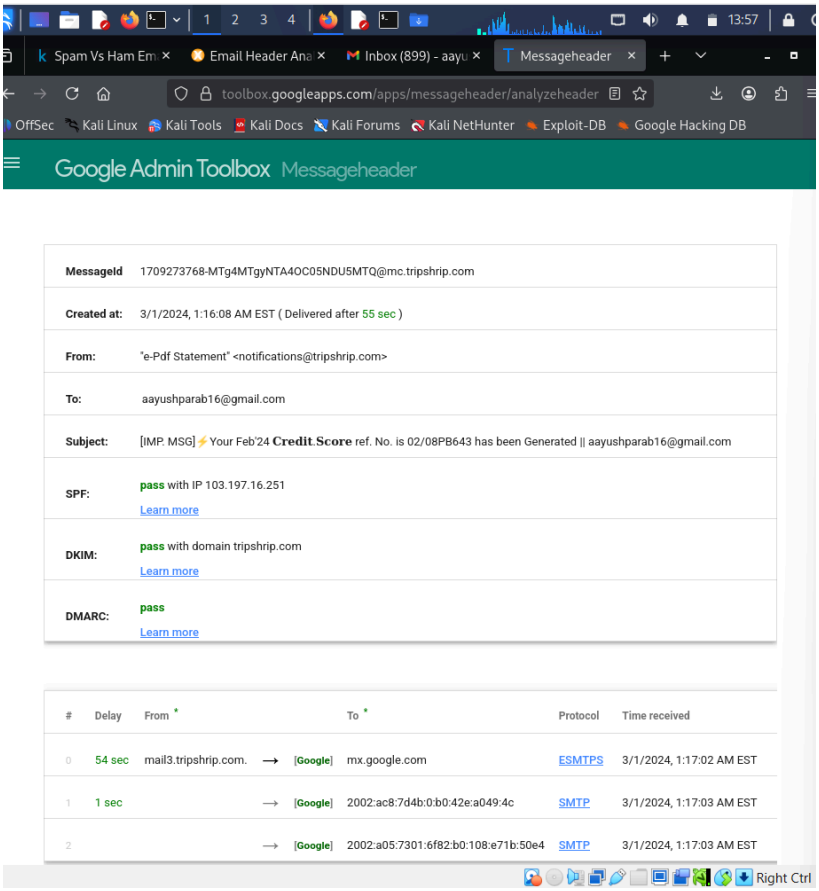
- Risk Level: High

Description: The sender appeared as "e-Pdf Statement", but the technical header confirms it originated from notifications@tripshrip.com. The email promises a free credit score update alongside a highly unrealistic ₹30,20,000 personal loan approval.

Impact:

- Theft of Personally Identifiable Information (PII)
- Redirection to malicious tracking domains

Proof of Concept: Payload used: Malicious image link redirecting to a third-party, non-banking domain.



Recommendation:

- Do not let urgency or greed dictate actions
- Ignore unsolicited financial offers promising massive payouts

5.3 Flexiloan Business Loan Scam

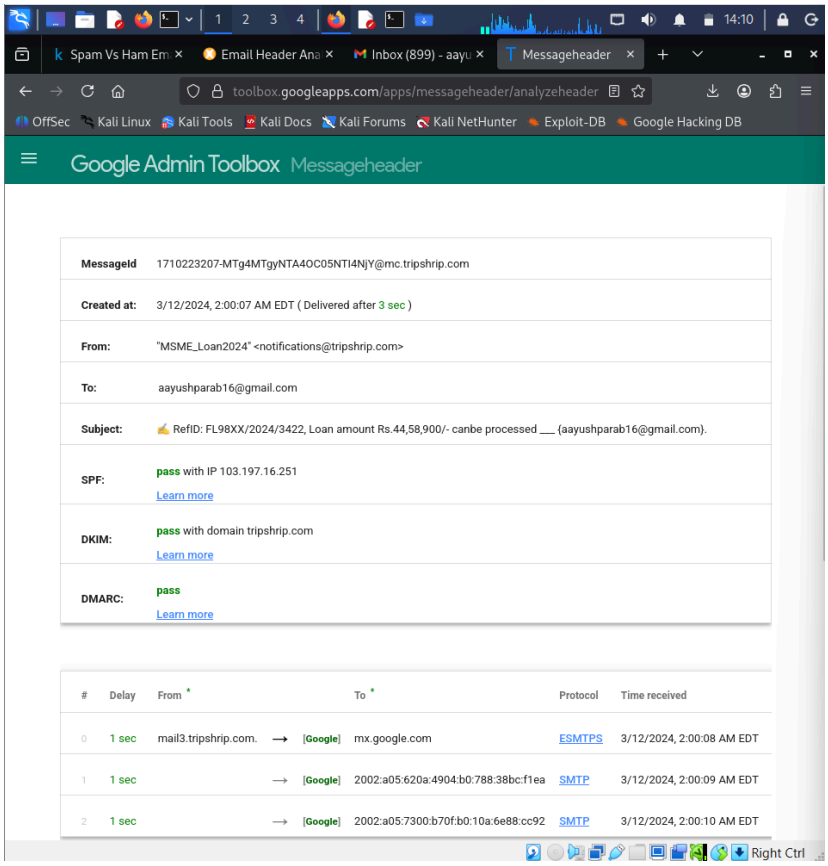
- Risk Level: High

Description: The sender's display name reads "MSME_Loan2024", attempting to look like an official government or corporate financial notification. It claims a ₹44,58,900 business loan is ready for processing with "Zero Paper Work."

Impact:

- Potential data breaches and misuse of sensitive information
- Financial fraud targeting business owners

Proof of Concept: Payload used: Embedded image redirecting to mc.tripshrip.com.



Recommendation:

- Independently verify loan statuses through official corporate channels
- Do not provide business credentials via email links

5.4 Fake Loan Approval Notification

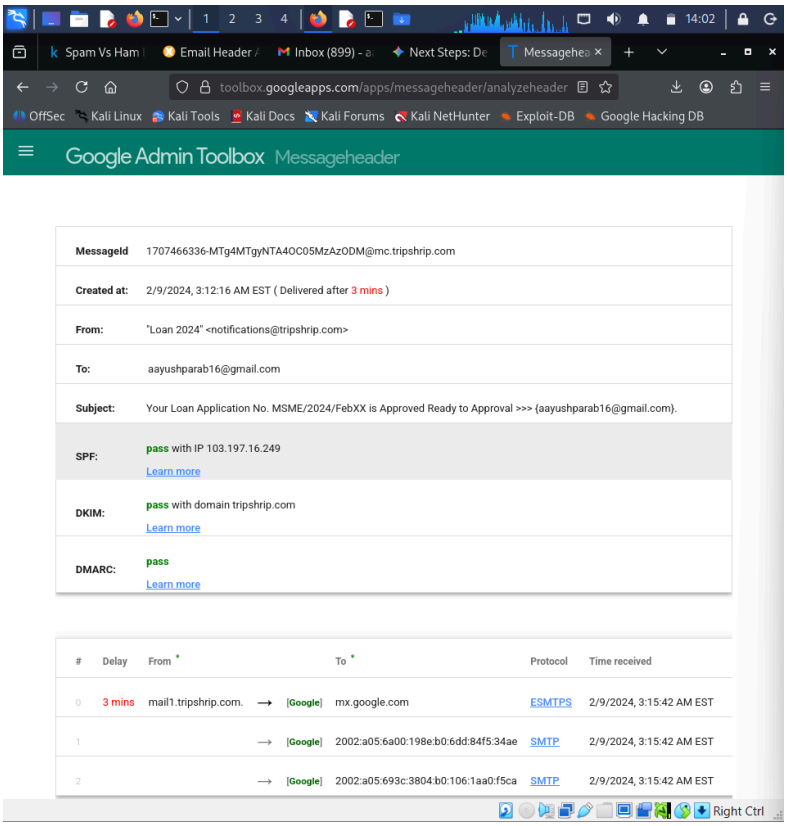
- Risk Level: High

Description: This email uses an image-based payload. The display name reads "Loan 2024", but the actual sending address is notifications@tripshrip.com. It claims a loan application (which the user never submitted) has been approved.

Impact:

- Execution of malicious scripts upon clicking the image
- Harvesting of user credentials

Proof of Concept: Payload used: A single image prompting the user to "Click Here," redirecting to the attacker's tracking domain.



Recommendation:

- Block images from unknown senders by default
- Do not click on emails that contain only a single, large image linking outward

6. Risk Summary

Risk Level	Count
Critical	0
High	4
Medium	0
Low	0
Informational	0

Analysis: The entirety of the identified threats fall under the High risk category, indicating significant campaigns targeting user credentials and financial data through social engineering and brand impersonation. Immediate awareness training is recommended to prevent potential exploitation.

7. Conclusion

The analysis revealed that attackers heavily rely on display name spoofing and psychological manipulation (greed, urgency, confusion) rather than technical exploits. By mimicking trusted financial institutions, these campaigns attempt to bypass user scrutiny. Similar vulnerabilities in human critical thinking could lead to serious security breaches, including data theft and system compromise.

8. Recommendations (Final Summary)

- Implement strict email filtering to flag external domains mimicking internal names
- Conduct security awareness training for developers and stakeholders
- Verify the sender's actual email address, not just the display name
- Hover before clicking to preview destination URLs
- Never provide sensitive information or login credentials via email links